

Security & Encryption Policy

Document: E-Numerak — Security & Encryption Policy (PEPPOL AS4) **Service Provider:** AL MERAK TAX CONSULTANT L.L.C **Date:** 2026-06-20 **Scope:** Technical security controls for the PEPPOL Access Point and platform.

1. Transport security (TLS)

- All API and PEPPOL traffic is served over **HTTPS / TLS**, terminated at nginx.
 - The public AS4 receiving endpoint (`/api/v1/inbound/as4/`) and all `/api/v1/` endpoints require TLS; plain HTTP is not served for production.
 - Certified in eDelivery testbed **TC2A.1 (TLS)**.
-

2. Message-level security (PEPPOL AS4 / WS-Security)

PEPPOL requires message-level signing **and** payload encryption on top of TLS. Implemented in `services/as4/` (`signing.py` , `encryption.py` , `envelope.py` , `sender.py` , `receiver.py`).

2.1 Digital signature (integrity + non-repudiation)

- Standard: **XML-DSig** within WS-Security (OASIS WSS 1.1 X.509 Token Profile).
- Signature algorithm: **RSA-SHA256** (`rsa-sha256`).
- Digest: **SHA-256**.
- Canonicalization: **Exclusive C14N** (`xml-exc-c14n#`).
- Signed parts: the `eb3:Messaging` header, the SOAP Body, the payload MIME attachment (digest over raw bytes), and the `wsu:Timestamp` .
- Key reference: X.509 **BinarySecurityToken** carrying the AP certificate.

2.2 Payload encryption (confidentiality)

Per PEPPOL AS4 the invoice payload is: 1. **gzip-compressed**, then 2. encrypted with **AES-128-GCM** using a **fresh symmetric key per message**, and 3. the symmetric key is wrapped with the recipient's RSA public key using **RSA-OAEP** (SHA-256 digest + **MGF1-SHA256**). 4. Carried as a binary MIME attachment (SwA Attachment-Ciphertext-Transform), wire format `IV(12) || ciphertext || GCM_tag(16)` .

2.3 Replay protection

- A `wsu:Timestamp` with a **5-minute validity window** (`TIMESTAMP_TTL_SECONDS`) bounds message freshness and mitigates replay.
-

3. Certificate trust & revocation

Implemented in `services/as4/cert_validation.py` ; PEPPOL trust anchors bundled in `services/as4/trust_anchors/` .

- **Outbound:** before sending, the recipient AP certificate (from SMP) is validated — full **chain build to a PEPPOL anchor + CRL revocation check**. On failure the message is **not transmitted** (certified TC2A.4, and the PINT-AE Business Document Validation suites).
 - **Inbound:** the signer certificate on a received AS4 message is run through the same chain + revocation gate (`PEPPOL_AS4_VERIFY_SIGNER_TRUST`). Untrusted signers are rejected (certified in the PKI G3 suite).
-

4. Key & secret management

- The AP private key + certificate live in a **password-protected PKCS#12** keystore (`certs/...p12.pfx`), mounted into the backend container.
 - The keystore password is provided via environment variable (`PEPPOL_KEYSTORE_PASSWORD`) — **never hard-coded or committed**.
 - Private keys are generated with `umask 077` (owner-read-only) and stored in a **git-ignored** directory.
 - Production private keys are generated **on the production host** and never transmitted (see [01-pki-g3-csr.md](#)).
 - Application secrets (DB, JWT signing, third-party API keys) are supplied via environment, not source control.
-

5. Application & access security

- **Authentication:** JWT bearer tokens (access + refresh) for all user-facing API endpoints.
 - **Multi-Factor Authentication (MFA):** TOTP-based MFA supported at login and in account settings (`/api/v1/auth/mfa/*`).
 - **Authorization:** role-based access (company members, inbound_supplier role, admin panel).
 - **Password security:** hashing via Django's password hashers; reset + email verification flows.
 - **Public surface minimisation:** only health probes and the m2m AS4 endpoint are unauthenticated; the AS4 endpoint is protected by WS-Security signature + signer trust validation rather than user auth.
-

6. Data validation (defence in depth)

- Every outbound and inbound business document is validated against **UBL XSD** and **PINT-AE Schematron** (Saxon) in `services/peppol/pint_ae/` .
 - Invalid documents are **rejected before transmission/acceptance** — proven in the PINT-AE Business Document Validation suites (valid docs sent, invalid docs gated).
-

7. Logging, monitoring & data residency

- Audit/event logging on invoice lifecycle and AS4 exchange.
- Health/readiness probes (`/health/` , `/ready/`) for availability monitoring.
- Captured AS4 messages stored for traceability (`media/as4_debug/`).
- **Data residency:** platform hosted for UAE operations — see the Hosting / Data Residency Confirmation document for the specific region.

8. Cryptographic summary

Control	Algorithm / Standard
Transport	TLS (HTTPS)
Signature	RSA-SHA256, Exclusive C14N, SHA-256 digest (XML-DSig / WSS 1.1)
Payload cipher	AES-128-GCM (fresh key per message)
Key wrap	RSA-OAEP (SHA-256 + MGF1-SHA256)
Compression	gzip (before encryption)
Certificate	X.509 RSA-2048, PEPPOL PKI G3
Replay window	5 minutes (wsu:Timestamp)

9. Compliance alignment

- **PEPPOL AS4 Profile v2.0** (§4 Security Layer).
- **OASIS ebMS 3.0, WSS 1.1 X.509 Token Profile, W3C XML-Enc/DSig.**
- **UAE PINT-AE** business document profiles + **AE TDD** tax reporting.
- Certified across the eDelivery (6/6), PKI G3 (3/3), and all four PINT-AE testbed suites (test PKI) — production PKI re-run pending for UAE accreditation.